AI Risk Register For Ashwood General Health Network

1. Company Profile

Attribute	Detail
Company	Ashwood General Health Network
Industry	Healthcare, multi-site hospital network
Size	2,200+ employees across 4 hospitals and 11 outpatient clinics in Lagos and Ogun State, serving roughly 500,000 patients annually
Data involved	Protected health information (diagnoses, medications, lab results, clinical notes, visit audio recordings), patient-reported symptoms and history, insurance/claims data, and the proprietary logic and training data behind the triage and authorization models

AI systems

1. **Scriba:** ambient AI clinical documentation assistant that listens to physician-patient visits and auto-drafts structured clinical notes, including diagnoses and medication orders, directly into the EHR. *Users: physicians and clinical staff.*
2. **TriageAI:** patient-facing symptom checker and triage chatbot on the hospital's app and website, advising patients whether to go to the ER, book urgent care, or self-manage at home. *Users: patients directly.*
3. **CareAuth:** internal decision-support tool for utilization review/case management staff, recommending approve/deny/limit decisions on inpatient length-of-stay and treatment authorizations. *Users: internal staff; decisions directly affect patient care.*

---

2. Risk Entries

R-01: PHI Leakage via AI Clinical Documentation Tool

Field	Detail
Affected AI system	Scriba
Description	Physicians under time pressure may paste patient details (symptoms, history, lab values) into Scriba's chat-assist mode, or Scriba's audio pipeline may

Field	Detail
	retain visit recordings with a third-party model vendor that lacks a signed Business Associate Agreement (in Nigeria, a data processing agreement). Either path exposes protected health information outside Ashwood's compliance boundary.
Related incident	Widely reported industry concern (covered by outlets such as Becker's Hospital Review and the HIPAA Journal) that clinicians pasting patient information into consumer-facing LLM tools creates HIPAA violations when no BAA governs how the model provider stores or uses that data.
Framework mapping	OWASP LLM06: Sensitive Information Disclosure
Likelihood	**High.** The workflow inherently requires PHI in Scriba's context on every visit.
Impact	**High.** PHI exposure triggers NDPR liability, patient trust damage, and potential loss of payer contracts.
Priority	**Critical**
Recommended mitigation	Use only a BAA-covered (or equivalent data-processing-agreement), zero-retention deployment of the underlying model; disable any general-purpose chat-assist mode not scoped to the current visit's audio; run automated PHI-handling audits quarterly.

R-02: Hallucinated Content in AI-Generated Clinical Notes

Field	Detail
Affected AI system	Scriba
Description	Ambient transcription models can fabricate content that was never spoken, inventing symptoms, medications or clinical findings. This flows into the permanent medical record if a physician doesn't catch it during review, creating downstream diagnostic and treatment errors.
Related incident	A 2024 AP investigation found that OpenAI's Whisper model, used as the transcription backbone in a medical documentation tool (Nabla) deployed across more than 30,000 clinicians, fabricated text, including invented

Field	Detail
	medical content, in a meaningful portion of transcripts examined by researchers.
Framework mapping	NIST AI RMF: Measure function (evaluating model accuracy/reliability in deployment)
Likelihood	**Medium.** Transcription hallucination is a documented, recurring failure mode of this category of tool.
Impact	**High.** Fabricated content in a clinical note can directly cause a misdiagnosis or wrong treatment.
Priority	**Critical**
Recommended mitigation	Require mandatory physician sign-off on every AI-drafted note before it is finalized in the EHR; visually flag AI-generated sections distinctly from physician-entered text; disable auto-population of medication or diagnosis fields without an explicit confirmation click.

R-03: Unsafe or Incorrect Triage Recommendations

Field	Detail
Affected AI system	TriageAI
Description	TriageAI may underestimate the severity of self-reported symptoms and recommend self-care or a delayed appointment when emergency care is warranted, particularly for rare, atypical or poorly represented presentations.
Related incident	Internal documents on IBM Watson for Oncology, reported by STAT News in 2018, showed the system in some cases recommended unsafe or incorrect cancer treatments, illustrating how confidently presented AI medical guidance can diverge from safe clinical practice without obvious signals to the user.
Framework mapping	NIST AI RMF: Measure function; OWASP LLM09: Overreliance

Field	Detail
Likelihood	**Medium.** Atypical presentations are inherently underrepresented in any triage model's training distribution.
Impact	**High.** A missed emergency triage recommendation can be life-threatening.
Priority	**Critical**
Recommended mitigation	Bias decision thresholds conservatively toward escalation for ambiguous or low-confidence cases; display a persistent "when in doubt, go to the ER" fallback message; route any symptom combination flagged high-risk by clinical guidelines to a mandatory nurse-line callback rather than a bot-only response.

R-04: Harmful Advice via Adversarial Manipulation of TriageAI

Field	Detail
Affected AI system	TriageAI
Description	A patient (particularly a vulnerable one) could phrase inputs to steer TriageAI outside its safety guardrails, for example eliciting specific dosage, fasting or self-treatment advice the system isn't designed to give safely, with the apparent authority of a hospital-branded tool.
Related incident	The National Eating Disorders Association's chatbot "Tessa" was taken offline in 2023 after users reported it gave harmful weight-loss and calorie-restriction advice.
Framework mapping	OWASP LLM01: Prompt Injection (adversarial framing to bypass safety behavior)
Likelihood	**Medium.** Vulnerable populations (eating disorders, mental health crises, chronic pain seeking medication) have documented patterns of probing chatbots for unsafe guidance.
Impact	**High.** Directly endangers patient safety and creates significant liability.
Priority	**Critical**

Field	Detail
Recommended mitigation	Hard-block specific dosage, fasting and restrictive-diet guidance regardless of framing; route crisis-adjacent language (self-harm, disordered eating, substance misuse) to an immediate human/crisis-line handoff; red-team quarterly with adversarial vulnerable-population framings.

R-05: Biased or Harmful Coverage Denials from CareAuth

Field	Detail
Affected AI system	CareAuth
Description	CareAuth's recommendations to deny or shorten inpatient stays could systematically disadvantage certain groups (e.g., elderly patients, patients with complex comorbidities poorly represented in training data) if case managers defer to the model over clinical judgment under productivity pressure.
Related incident	UnitedHealth's NaviHealth "nH Predict" algorithm was the subject of 2023 lawsuits alleging it was used to systematically deny or cut short rehabilitation and post-acute care for elderly patients, with its recommendations reportedly overriding treating physicians' judgment.
Framework mapping	NIST AI RMF: Govern function (fairness and accountability) and Map function (context-specific harm)
Likelihood	**Medium.** Cost-containment pressure in utilization review creates real risk of over-deference to automated denial recommendations.
Impact	**High.** Directly harms care outcomes and creates legal and regulatory exposure.
Priority	**Critical**
Recommended mitigation	Require documented clinical justification whenever a case manager follows a denial/reduction recommendation; audit denial rates by demographic and diagnosis category quarterly for disparate impact; keep CareAuth advisory-only, never a final decision, with physician override free of administrative friction.

R-06: Model Extraction of CareAuth's Proprietary Authorization Logic

Field	Detail
Affected AI system	CareAuth
Description	If CareAuth is exposed via API to third-party insurance partners for pre-authorization, systematic querying with varied synthetic patient profiles could let a partner or bad actor reverse-engineer its decision logic, enabling gaming of authorizations or theft of proprietary clinical-risk IP.
Related incident	Academic research on model-stealing attacks against commercial ML-as-a-service APIs has repeatedly shown black-box decision models can be closely approximated through systematic query probing alone.
Framework mapping	OWASP LLM10: Model Theft
Likelihood	**Low-Medium.** Requires sustained, deliberate probing, but partner-facing API exposure raises the risk over an internal-only deployment.
Impact	**Medium.** Loss of proprietary logic and a route to gaming authorizations, though less severe than direct patient-safety risks.
Priority	**Medium**
Recommended mitigation	Rate-limit and anomaly-monitor authorization API calls per partner; return only categorical decisions (no confidence scores or feature weights); contractually restrict partner use to legitimate single-patient authorization requests.

R-07: Drift or Poisoning of TriageAI from Adversarial Symptom Reporting

Field	Detail
Affected AI system	TriageAI
Description	If TriageAI is periodically fine-tuned or recalibrated on aggregated patient interaction logs, a coordinated pattern of misleading self-reported symptoms

Field	Detail
	(malicious or simply widespread inaccurate reporting) could gradually shift triage thresholds, causing under- or over-triage of certain symptom clusters.
Related incident	No directly comparable incident was identified for this specific pattern. It is included as a plausible extension of general training-data poisoning seen in deployed AI systems (e.g., Microsoft's 2016 Tay chatbot, measurably shifted by coordinated adversarial input within 24 hours), applied to TriageAI's likely future retraining pipeline.
Framework mapping	OWASP LLM03: Training Data Poisoning; NIST AI RMF: Manage function
Likelihood	**Low.** Requires coordinated malicious effort or an unusually large systematic reporting bias.
Impact	**High.** Undermines the safety calibration of every future triage decision.
Priority	**Medium**
Recommended mitigation	Never retrain directly on raw interaction logs without clinical review of sampled data; maintain a fixed, clinically validated holdout test set to detect drift after each retraining; require clinical sign-off before deploying any recalibrated model.

R-08: Insecure Handling of AI-Generated Content in the EHR

Field	Detail
Affected AI system	Scriba
Description	If Scriba's structured outputs (medication name, dosage, frequency) are auto-populated into discrete EHR fields without per-field confirmation, a transcription error or fabrication becomes structured data that other systems (pharmacy, billing, clinical alerts) may act on directly.
Related incident	ECRI Institute's 2024 Top 10 Health Technology Hazards report named AI in healthcare among its leading hazards, with concern that AI-drafted content

Field	Detail
	can enter the record with unnoticed errors because it looks authoritative and complete.
Framework mapping	OWASP LLM02: Insecure Output Handling
Likelihood	**Medium.** Auto-population into structured fields is a common design choice because it saves clinician time.
Impact	**High.** A dosage error propagating automatically to pharmacy or alert systems is a direct patient-safety failure.
Priority	**High**
Recommended mitigation	Require explicit per-field physician confirmation before any AI-drafted medication, dosage or diagnosis field is committed to the EHR (no silent auto-population); build discrete-field validation rules (e.g., dosage range checks) that flag AI-drafted values for review before they can propagate to pharmacy or billing.

---

3. Executive Summary

Ashwood's three AI systems sit at points where an error doesn't just cost money; it can directly affect patient safety, raising the stakes of every risk in this register above a typical AI deployment. The most urgent exposures are hallucinated content entering the permanent medical record via Scriba and unsafe triage guidance from TriageAI, both with direct, well-documented real-world precedents. CareAuth's coverage-decision risk closely mirrors an active industry controversy (the nH Predict lawsuits) and deserves governance attention now, before Ashwood faces comparable legal exposure.

We recommend treating R-01 through R-05 as immediate priorities this cycle, with mandatory human review points added at every stage where AI output currently flows into the record or into a patient-facing recommendation without a confirmation step.